

Ticket 001 - SSH Authentication Incident Report

Repeated login failures followed by successful access

Status	Closed	Work dates	July 20 and July 22, 2026
Total effort	4 hours	Environment	Authorized isolated lab

Executive Summary

An investigation was conducted after repeated SSH authentication failures were observed against the sshlab account on the Ubuntu server at 192.168.56.121. The activity originated from the Kali Linux system at 192.168.56.111. Eleven failed password attempts were followed by a successful SSH login from the same source IP and account.

After authentication, the user created /tmp/ticket001-access.txt, confirming that the account was used to perform post-login activity. Native Linux logs, login-history records, Wazuh alerts, file metadata, and screenshots supported the conclusion that the repeated failures were followed by successful access.

Containment included locking the affected account and testing a temporary nftables source-IP block. A custom SSH brute-force detector was also created and scheduled through cron. The incident was an authorized lab simulation, but it demonstrated weaknesses that would be significant in a production environment, including password-based SSH, the absence of automated lockout or rate limiting, and an initial Wazuh visibility gap.

1. Incident Overview

Field	Details
Incident type	SSH password attack simulation followed by successful authentication
Target account	sshlab
Source system	Kali Linux - 192.168.56.111
Target system	Ubuntu - 192.168.56.121
SIEM platform	Wazuh manager/dashboard - 192.168.56.122
Wazuh agent	ubuntu-lab7
Outcome	Successful access confirmed; account contained; detections validated
Confidence	High

2. Investigation Scope and Objectives

The investigation was designed to answer five primary questions:

1. What happened and in what sequence?
2. Which source system and account were involved?
3. Did the authentication activity result in successful access?
4. What evidence supports the conclusion?
5. What containment and detection improvements were appropriate?

3. Systems and Tools

System / Tool	Role	Key Detail
Windows host	Administration and final evidence storage	192.168.56.1
Kali Linux	Simulated source of failed and successful SSH attempts	192.168.56.111
Ubuntu	SSH target and Wazuh agent host	192.168.56.121
Wazuh	SIEM alerting and correlation	192.168.56.122; agent ubuntu-lab7
Linux logging	Primary authentication evidence	journalctl, last, lastb
nftables	Temporary network containment	Source-IP SSH drop rule
Custom Bash detector	Five-minute SSH failure threshold	Scheduled through root cron
PowerShell / OpenSSH	Project transfer, hashing, ZIP verification	Windows host

4. Attack and Investigation Flow

Repeated failures	Wazuh alert	Successful login	Post-login activity	Containment and detection
-------------------	-------------	------------------	---------------------	---------------------------

The same source IP and target account appeared throughout the sequence, allowing the failed attempts, successful access, and subsequent activity to be correlated with high confidence.

5. Technical Timeline

UTC Time	Event	Evidence	Interpretation
18:29:54	First failed SSH password attempt from 192.168.56.111 to sshlab	SSH service log / lastb	Beginning of concentrated authentication activity
18:29:54-18:31:41	Eleven failed attempts recorded	failed-logins.txt; failed-attempts-by-ip.txt	Repeated credential guessing against one account
During failure burst	Wazuh rule 5551, level 10	Wazuh screenshot and findings	Multiple failed PAM logins detected; MITRE T1110
18:36:50	Password accepted for sshlab from 192.168.56.111	successful-login-session.txt; last	Successful access confirmed
18:36:50	Wazuh rule 40112, level 12	Wazuh screenshot and findings	Failures followed by success; MITRE T1078/T1110
18:39:23	/tmp/ticket001-access.txt created by sshlab	post-login-artifact.txt	Post-login activity confirmed
18:40:47	SSH session closed	successful-login-session.txt	Session duration bounded
After validation	sshlab account locked	containment-account-lock.txt	Credential use prevented while preserving account
After containment test	Temporary nftables SSH block applied and removed	containment-firewall-rule.txt	Source-IP containment validated
19:40:38 onward	Custom detector generated manual and cron alerts	custom-detection-alert.txt; automatic-detection-alerts.txt	Detection improvement validated

6. Evidence Collected

The conclusion was supported by multiple independent evidence sources:

Evidence category	Files / source	What it established
SSH logs	complete-ssh-incident-log.txt; failed-logins.txt	Failure sequence, source IP, account, accepted login, session state
Login history	lastb-failures.txt; last-successful-login.txt	Independent failed and successful authentication history
Source aggregation	failed-attempts-by-ip.txt	Concentration of failures from 192.168.56.111
Post-login artifact	post-login-artifact.txt	Ownership, content, and creation time of the test file
Wazuh findings	wazuh-alert-findings.txt and two screenshots	Rule 5551 and rule 40112 detections
Agent state	wazuh-agent-state.txt	Initial monitoring gap and later connectivity
Containment	containment-account-lock.txt; containment-firewall-rule.txt	Account lock and temporary network block
Detection improvement	detect-ssh-bruteforce.sh; root-crontab.txt; alert logs	Manual and automated custom detection
Integrity	evidence-inventory.txt; evidence-hashes.txt	Evidence inventory and SHA-256 verification

7. Key Findings

- The failed and successful SSH events originated from 192.168.56.111 and targeted the sshlab account.
- Eleven failed password attempts were recorded before successful authentication.
- The accepted password event and session-open record confirmed access to the Ubuntu server.
- The file /tmp/ticket001-access.txt confirmed activity after authentication.
- Wazuh detected both the failure burst and the failures-followed-by-success sequence.
- The Wazuh agent was initially pending or disconnected, creating a temporary visibility gap.
- The first custom detector was functional but generated duplicate alerts while the same events remained in its five-minute window.

8. Root Cause Analysis

The immediate cause was successful password authentication to the sshlab account after repeated failed attempts. The account remained available, password-based SSH authentication was enabled, and no automated lockout or source-based rate limiting prevented continued attempts.

A valid password was then used from the same source IP, allowing access. In this authorized simulation the success was intentional, but the control weaknesses would create material risk in a production environment.

Contributing factors included:

- Password-based SSH authentication was enabled.
- The account did not automatically lock after repeated failures.
- No automated blocking control was active before the test.
- Wazuh visibility was incomplete during the first portion of testing.
- The custom detector lacked persistent state and duplicate suppression.

9. Wazuh Detection Results

Rule	Level	Description	MITRE ATT&CK	Assessment
5551	10	PAM: Multiple failed logins in a small period	T1110 - Brute Force	Correctly identified the concentrated failure

Rule	Level	Description	MITRE ATT&CK	Assessment
		of time		burst
40112	12	Multiple authentication failures followed by a success	T1078 - Valid Accounts; T1110 - Brute Force	Correctly correlated failure activity with later successful access

Detection strength: the existing Wazuh rules captured both the repeated failures and the higher-risk transition to successful authentication. Detection limitation: alert completeness depended on agent connectivity, so native host logs remained essential.

10. Containment and Remediation Actions

Action	Reason	Result	Status
Locked sshlab account	Stop further password authentication while preserving the account	Account status changed to locked	Completed
Applied temporary nftables rule	Validate source-IP SSH containment	Traffic from 192.168.56.111 to TCP/22 dropped; rule later removed for testing	Completed
Validated Wazuh agent connectivity	Restore SIEM visibility	Subsequent events reached Wazuh	Completed
Created custom detector	Add lightweight local detection for repeated failures	Threshold alerts generated manually and by cron	Completed with known limitation
Preserved and hashed evidence	Support handoff and integrity verification	All listed files passed SHA-256 checks	Completed

11. Significant Technical Decisions

Account lock: Chosen because it immediately prevented additional password authentication while preserving the account for investigation.

Temporary source-IP block: Used as a containment test, not a permanent identity control, because IP addresses can be shared, reassigned, or spoofed.

Five failures in five minutes: Selected to detect concentrated activity while reducing alerts from one or two accidental password errors.

Cron scheduling: Used as a lightweight automation mechanism suitable for a lab without introducing another long-running service.

Native log correlation: Used because SIEM visibility was initially incomplete and no single telemetry source should be treated as the only source of truth.

SHA-256 hashing: Used to demonstrate that evidence files remained unchanged after collection and packaging.

12. Alternative Hypotheses Considered

Hypothesis	Evaluation	Conclusion
Failures and success came from different actors	Source IP and target account matched across the sequence	Not supported by available evidence
Successful login was unrelated to the failures	Timing, source, account, and Wazuh correlation aligned	Unlikely
Post-login file was created by another user	File metadata identified sshlab and aligned with the session window	Not supported
Wazuh alone proved the incident	Native host logs independently confirmed the sequence	Wazuh was supporting, not exclusive, evidence

13. Investigation Limitations

- The activity occurred in a controlled lab and did not include production business impact.
- The Wazuh agent was not fully connected during the earliest portion of testing.
- No packet capture was collected for the SSH session.
- The post-login activity was intentionally limited to one test file.
- The first detector version did not persist state or suppress duplicate alerts.
- The investigation confirms account use but does not attempt to attribute a real-world person.

14. Recommendations

1. Disable SSH password authentication where operationally possible and require public-key authentication.
2. Use multifactor authentication for privileged remote access where supported.
3. Apply account lockout, rate limiting, Fail2ban, or an equivalent automated control.
4. Remove or disable unused accounts and review SSH access regularly.
5. Alert on Wazuh agent disconnection and verify SIEM ingestion before security testing.
6. Review successful logins that occur shortly after repeated failures and preserve native host logs.
7. Improve the custom detector with state tracking, aggregation, structured output, and duplicate suppression.
8. Synchronize time and automate evidence inventory, hashing, packaging, and verification.

15. Lessons Learned

Question	Answer
What was the problem?	Repeated SSH failures were followed by successful access and post-login activity.
What evidence was collected?	SSH logs, login history, Wazuh alerts, file metadata, containment records, screenshots, timeline, inventory, and hashes.
What incorrect assumption was made?	The Wazuh agent was assumed to be connected, and the first Windows scp path was assumed to be valid.
How was it solved?	Native logs were correlated, agent connectivity was validated, controlled events were repeated, and the transfer path was corrected.
What will be done differently?	Validate monitoring first, document during the work, define expected results, and automate packaging and verification.

16. Final Conclusion

The investigation confirmed that repeated SSH password failures from 192.168.56.111 against the sshlab account were followed by successful authentication and post-login activity. Independent Linux logs, Wazuh correlation alerts, login history, file metadata, containment records, and integrity-verified artifacts support the conclusion. The account was contained, a temporary network block was tested, and a custom detector was implemented. The ticket met the documented Definition of Done and is ready for portfolio submission.

Final status	Closed - investigation complete and ready for portfolio submission
--------------	---